OpenCTI - APT29

Threat intelligence analysis report - APT29 campaigns, tooling and phishing infrastructure

Subject of analysis	APT29 (aliases: Cozy Bear, IRON HEMLOCK, NobleBaron, Dark Halo, NOBELIUM, UNC2452)
Attribution	Widely attributed to Russia's Foreign Intelligence Service (SVR)
Intelligence platform	OpenCTI (STIX2-based threat intelligence platform)
Evidence analyzed	OpenCTI intrusion set, campaign, tool, attack pattern, indicator, observable and report records, plus the external threat reports they reference
Tools used	OpenCTI, MITRE ATT&CK kill chain view, AlienVault OTX
Overall result	APT29 profiled end to end: campaign history, arsenal, ATT&CK techniques and phishing infrastructure, with actionable indicators extracted for detection and response

1. Executive Summary

The company was attacked by APT29, a Russian state-sponsored espionage group that targets government, diplomatic and policy organizations. To understand who we are facing and what to hunt for, I worked from my analyst workstation in OpenCTI, the threat intelligence platform we use to store and relate adversary data, and built a profile of the actor from the records on file.

The intelligence shows a patient and adaptive adversary. APT29 is linked to two major campaigns (the SolarWinds Compromise and Operation Ghost), a 15-tool arsenal that includes the meek Tor plugin for hiding traffic inside HTTPS, and 160 ATT&CK attack patterns. Its 2023 operations used diplomatic-themed phishing lures (Czechia, Türkiye, Norway and Poland themes) to deliver ISO, ZIP, PDF and SVG payloads built around the ROOTSAW dropper, with a malicious shortcut that launches a DLL through rundll32. The domains, URLs, file names and hashes gathered here can be used immediately for blocking and retrospective hunting.

2. Scope and Evidence

This report covers the investigation scenario available at https://cyberdefenders.org/blueteam-ctf-challenges/opencti-101-apt29/. No packet captures or host images were supplied. The evidence is the threat intelligence held in the OpenCTI instance, together with the external reports that its records point to. Every finding below comes from those records, and the figures are screenshots captured during the analysis.

3. Background: APT29 and OpenCTI

APT29 is one of the most sophisticated and persistent threat actors tracked today. It is known under many names, including Cozy Bear, IRON HEMLOCK, NobleBaron, Dark Halo, NOBELIUM and UNC2452, and its operations are characterized by advanced tradecraft, constant innovation in delivery techniques and a steady focus on intelligence collection.

OpenCTI organizes threat data using the STIX2 standard. Intrusion sets, campaigns, malware, tools, attack patterns, indicators, observables and reports are all separate entity types linked by relationships, which makes it possible to pivot from one piece of evidence to everything connected with it. That pivoting

is the method used throughout the phases below.

4. Investigation Phases

Phase 1 - Locating APT29 and Its Campaigns

I started with the platform's global search for "APT29". The results mixed several entity types: the intrusion set itself (7 analyses attached), reports from AlienVault, and malware entries such as HAMMERTOSS, SoreFang, WellMail, QUIETEXIT and WellMess. I opened the entry typed as an intrusion set to reach the actor's profile.

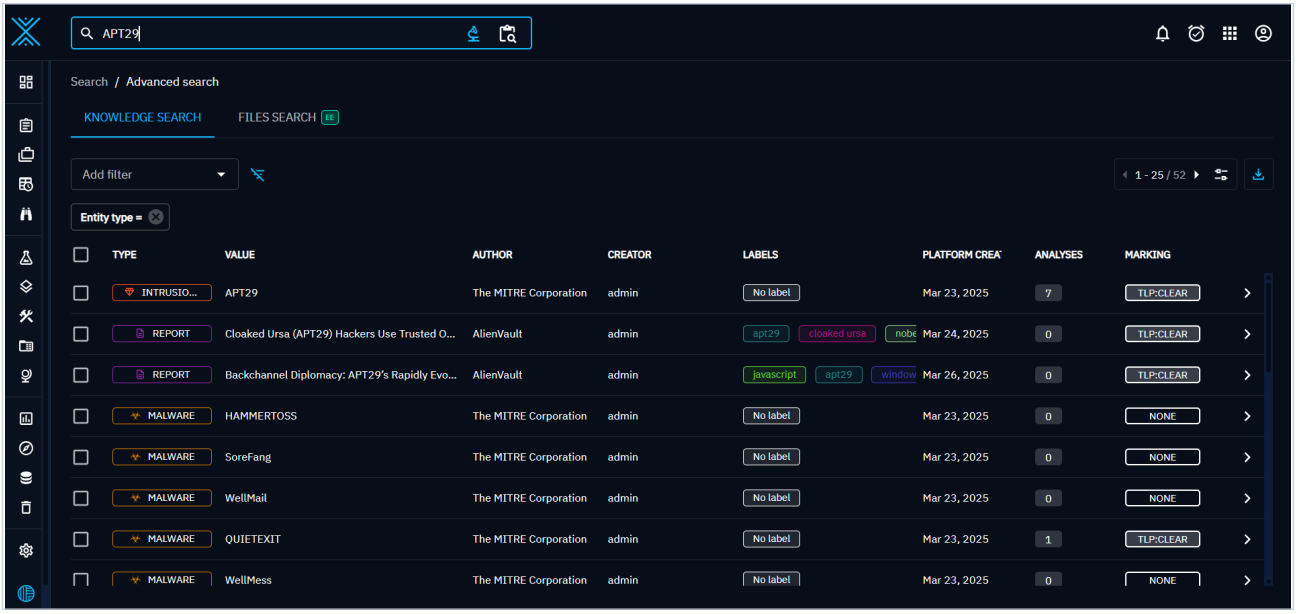


Figure 1. Knowledge search for "APT29" returning the intrusion set, related reports and associated malware.

On the profile page, the Knowledge tab lists everything linked to the actor, and its right-hand panel summarizes the volume: 10 victimology entries, 2 campaigns, 35 malware, 15 tools, 160 attack patterns and 91 indicators. The Campaigns section shows the two operations associated with APT29: **SolarWinds Compromise**, the 2020 supply chain attack carried out through trojanized SolarWinds Orion updates, and **Operation Ghost**.

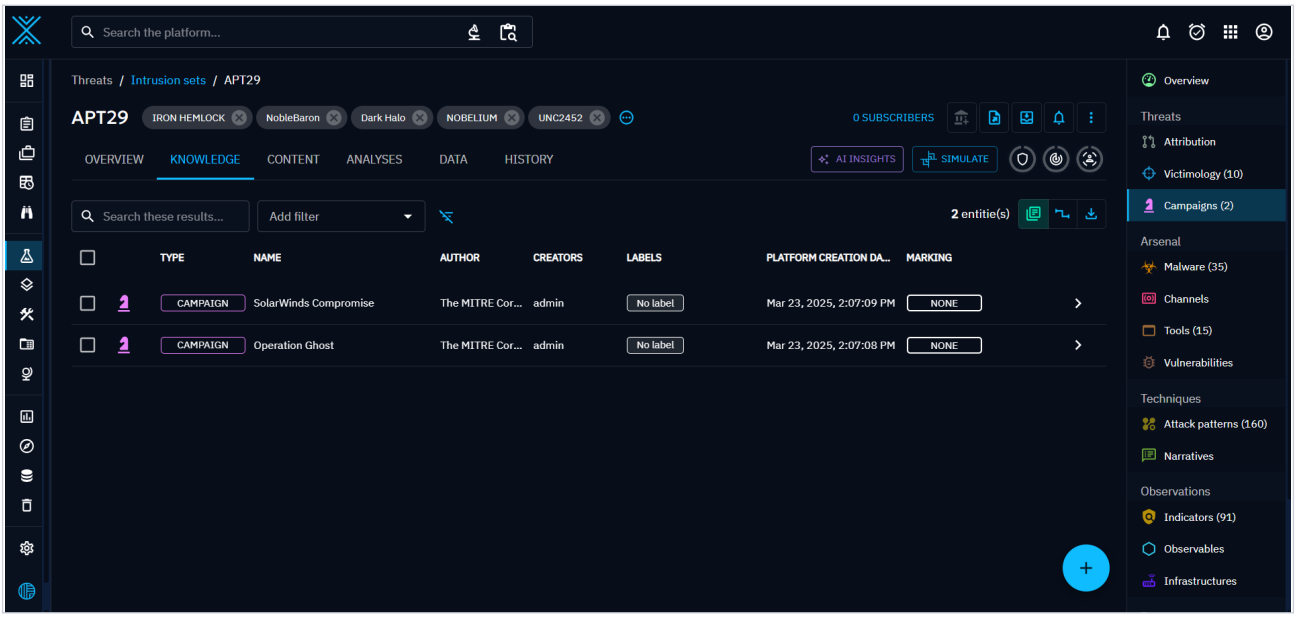


Figure 2. APT29 intrusion set, Knowledge tab: the two linked campaigns, SolarWinds Compromise and Operation Ghost.

Phase 2 - Reviewing the Arsenal: Tools

Knowing which tools an actor uses reveals how it operates and how it evades detection. From the same Knowledge tab I opened the Tools category under Arsenal, which holds 15 tools linked to APT29. The list mixes legitimate administration utilities and offensive frameworks: Sliver, SDelete, ROADTools, PsExec, Net, Mimikatz, ipconfig, Impacket, BloodHound, AdFind and AADInternals among them.

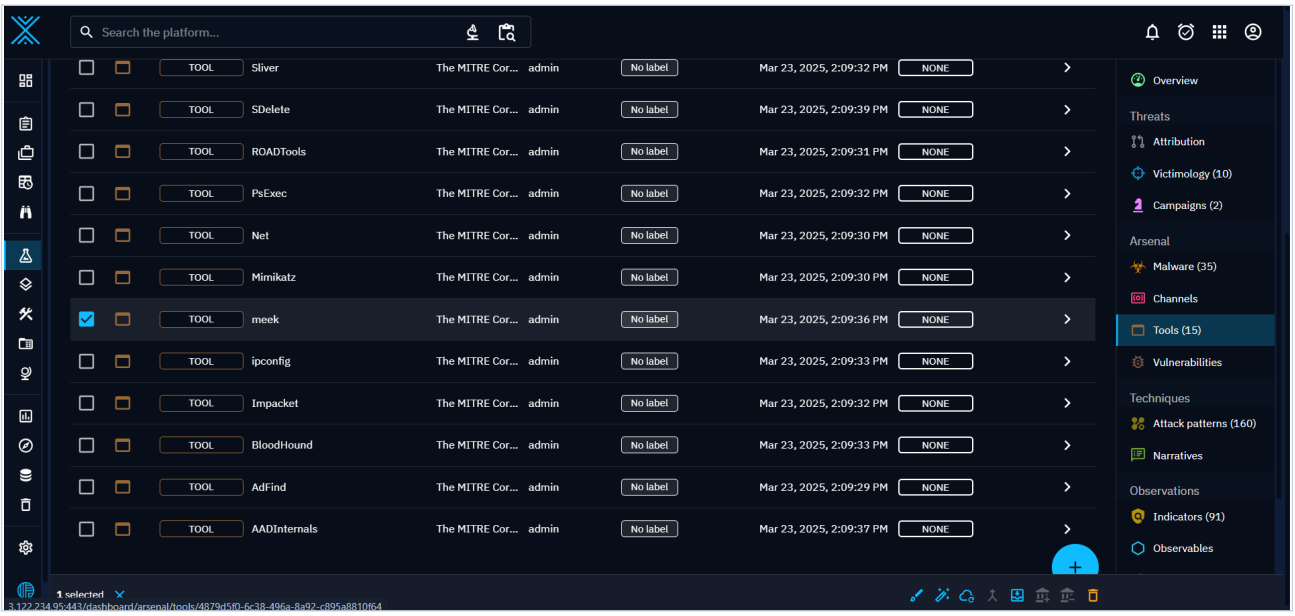


Figure 3. Tools linked to APT29 (15 entities), with the meek entry selected.

One entry stood out for evasion: **meek**. Its overview describes it as an open-source Tor plugin that tunnels Tor traffic through HTTPS connections. In practice this disguises Tor communication as ordinary HTTPS traffic to legitimate services (domain fronting), which makes it much harder for network defenders to spot and block. Its presence in the arsenal shows the group takes operational security seriously.

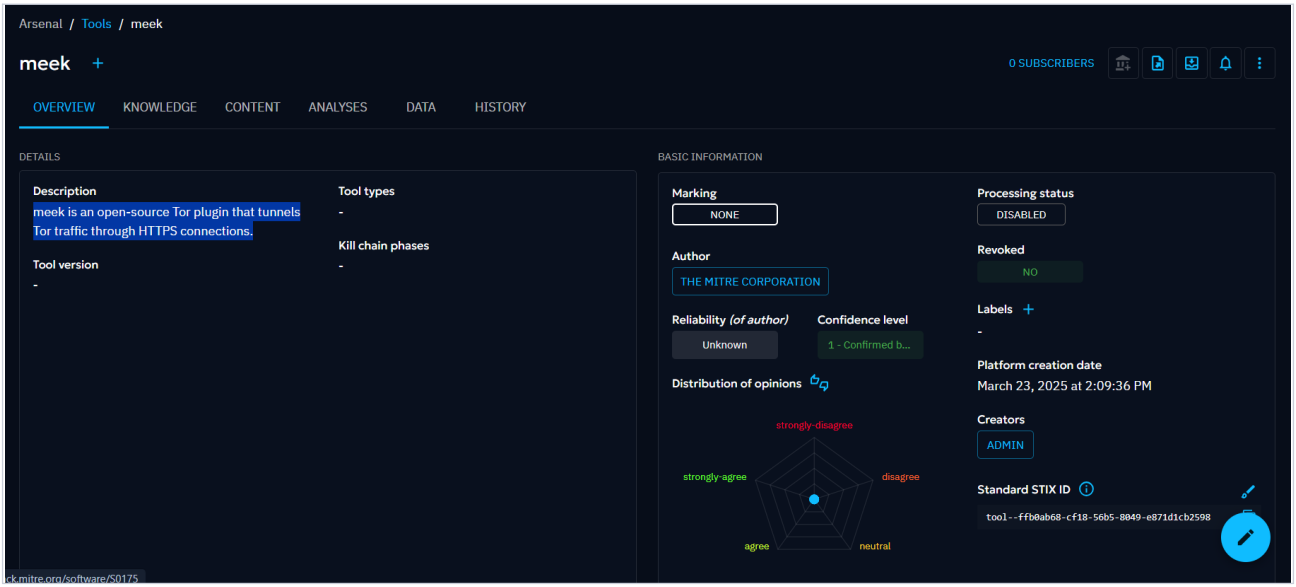


Figure 4. meek tool record: an open-source Tor plugin that tunnels Tor traffic through HTTPS connections.

Phase 3 - Mapping Behavior to MITRE ATT&CK

To see how APT29 behaves in terms every analyst shares, I opened the Attack patterns section (160 entries) and switched to the kill chain view filtered on the mitre-attack framework. This arranges every technique under its tactic column. The exfiltration column holds 9 techniques, and the most recently observed ones are **T1030** (Data Transfer Size Limits), where data is split into smaller chunks to stay under detection thresholds, and **T1048** (Exfiltration Over Alternative Protocol), where non-standard protocols carry stolen data past monitoring built around common ones.

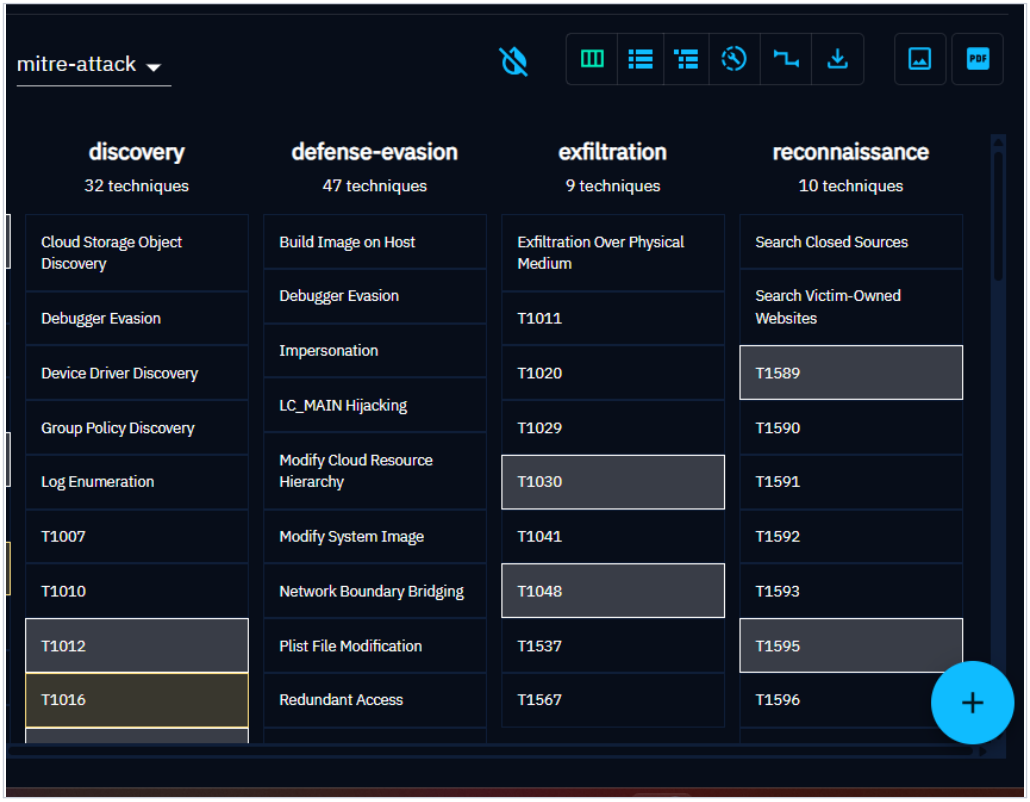


Figure 5. MITRE ATT&CK kill chain view of APT29 attack patterns; the exfiltration column (9 techniques) shows T1030 and T1048 highlighted.

Phase 4 - Pivoting on Infrastructure: crossfity[.]com

Domains are valuable indicators because actors depend on them for command and control and for delivery. I searched the platform for the domain **crossfity[.]com**, which was tied to APT29 activity. The knowledge search returned two records, an Indicator and a Domain Name observable, both authored by AlienVault and carrying the labels apt29, cloaked ursa and nobelium.

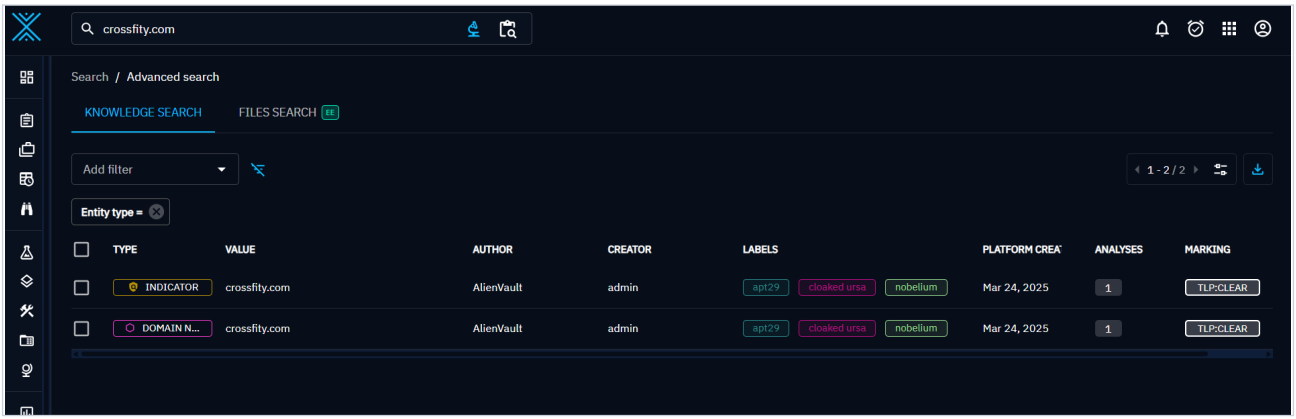


Figure 6. Knowledge search for crossfity.com returning an Indicator and a Domain Name observable tagged apt29, cloaked ursa and nobelium.

Opening the indicator and reading its Knowledge tab shows four relationships. The indicator *indicates* two malware entities, **Cobalt Strike** and **EnvyScout**, plus the APT29 intrusion set, and it is *based on* the domain name observable. Cobalt Strike is a commercial adversary emulation tool built for penetration testing but widely abused for post-exploitation, lateral movement and command and control. EnvyScout is a malware family tied to APT29 and typically used as an initial access dropper delivered through spear-phishing.

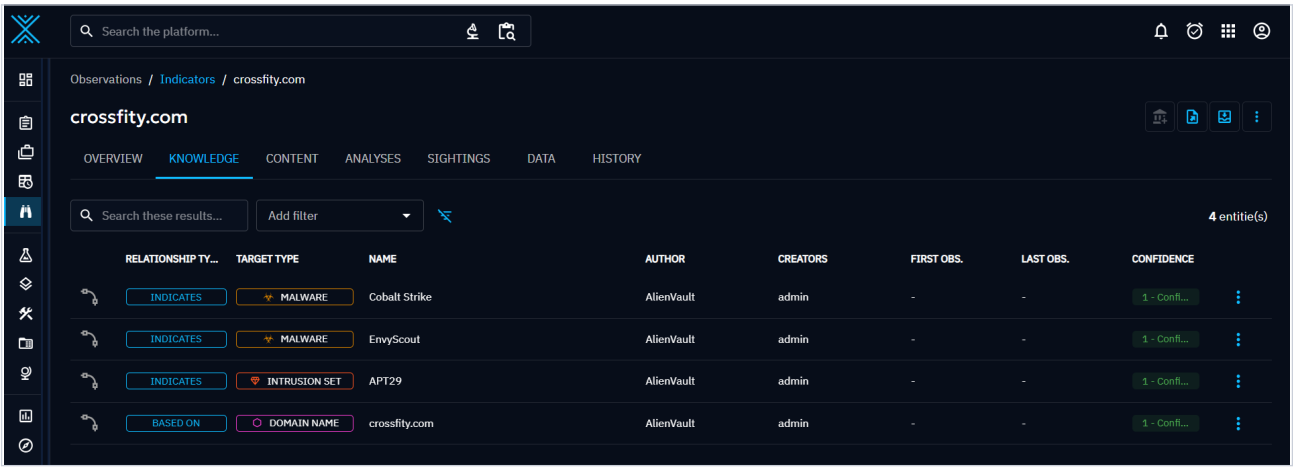


Figure 7. Relationships of the crossfity.com indicator: Cobalt Strike, EnvyScout and APT29, plus its domain name observable.

Phase 5 - Identifying Related Infrastructure

Actors rarely rely on a single domain, so I looked for what else was reported alongside crossfity[.]com. The bottom of the indicator's Overview page lists the containers that reference it. One report appears there: **Cloaked Ursa (APT29) Hackers Use Trusted Online Storage Services**, authored by AlienVault. The record history also confirms the indicator was created in the platform on March 24, 2025.

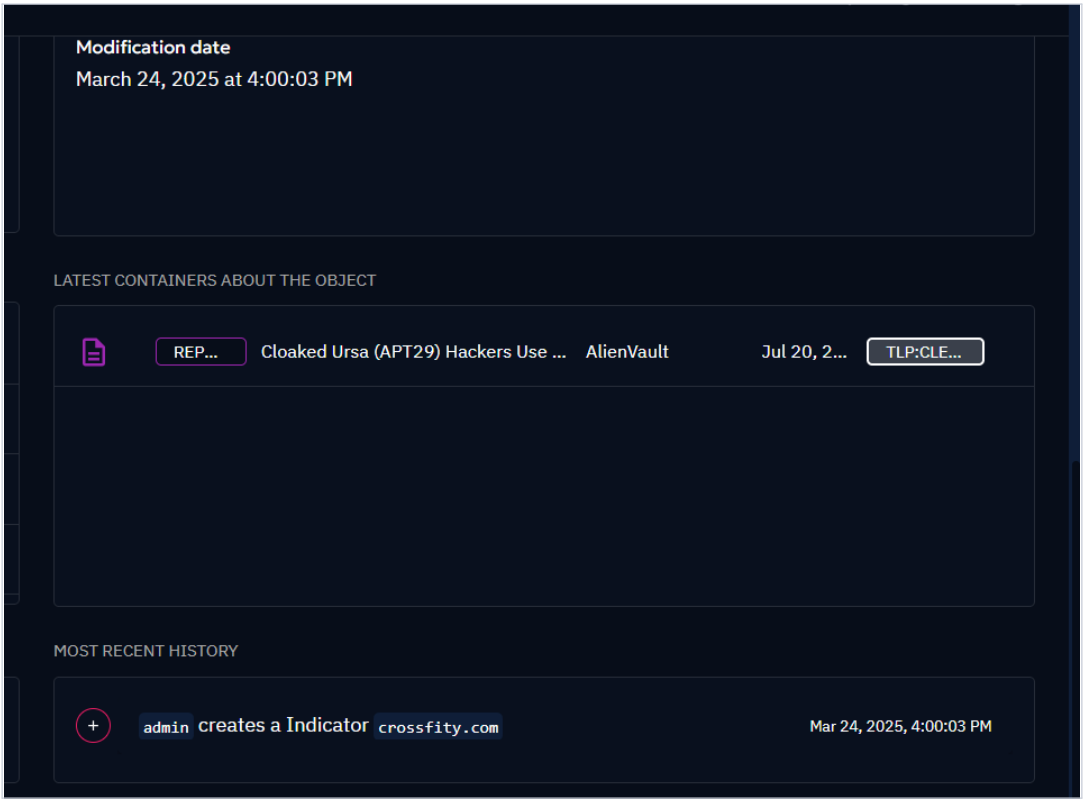


Figure 8. Overview of crossfity.com: the report that references the indicator and the record's most recent history.

Inside that report, the entities and observables list 29 items, including attack patterns and indicators. Alongside crossfity[.]com the report documents a second domain, **techspaceinfo[.]com**, labeled apt29 and cloaked ursa. Both domains belong to the same campaign abusing trusted online storage services, which is a good example of how actors keep redundant infrastructure.

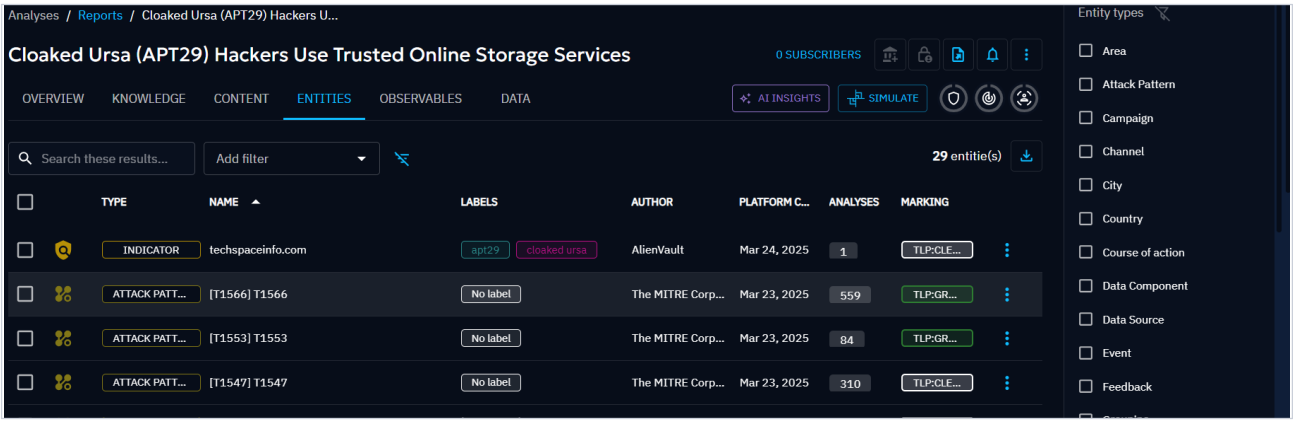


Figure 9. Entities of the Cloaked Ursa report (29 entities), including the second domain, techspaceinfo.com.

Phase 6 - 2023 Diplomatic Phishing: April 2023 Operation

Next I turned to APT29's 2023 phishing operations. Searching the platform for the apt29 label with the report entity type returned four reports, among them **Backchannel Diplomacy: APT29's Rapidly Evolving Diplomatic Phishing Operations**.

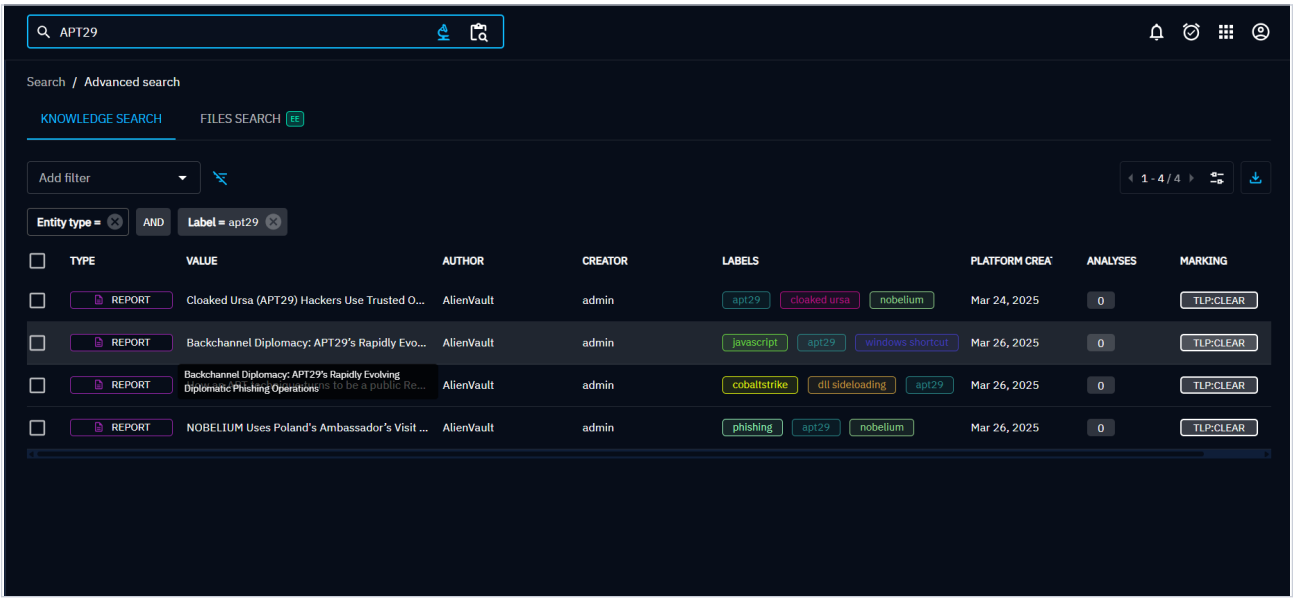


Figure 10. Search results for APT29 reports filtered by the apt29 label, including the Backchannel Diplomacy report.

The report was published on September 25, 2023 and describes APT29's increased operational tempo and emphasis on Ukraine in the first half of 2023, pointing to the SVR's central role in collecting intelligence during that phase of the war. Its External References section links to the original Mandiant analysis and to an AlienVault OTX pulse, and two other correlated reports sit beside it.

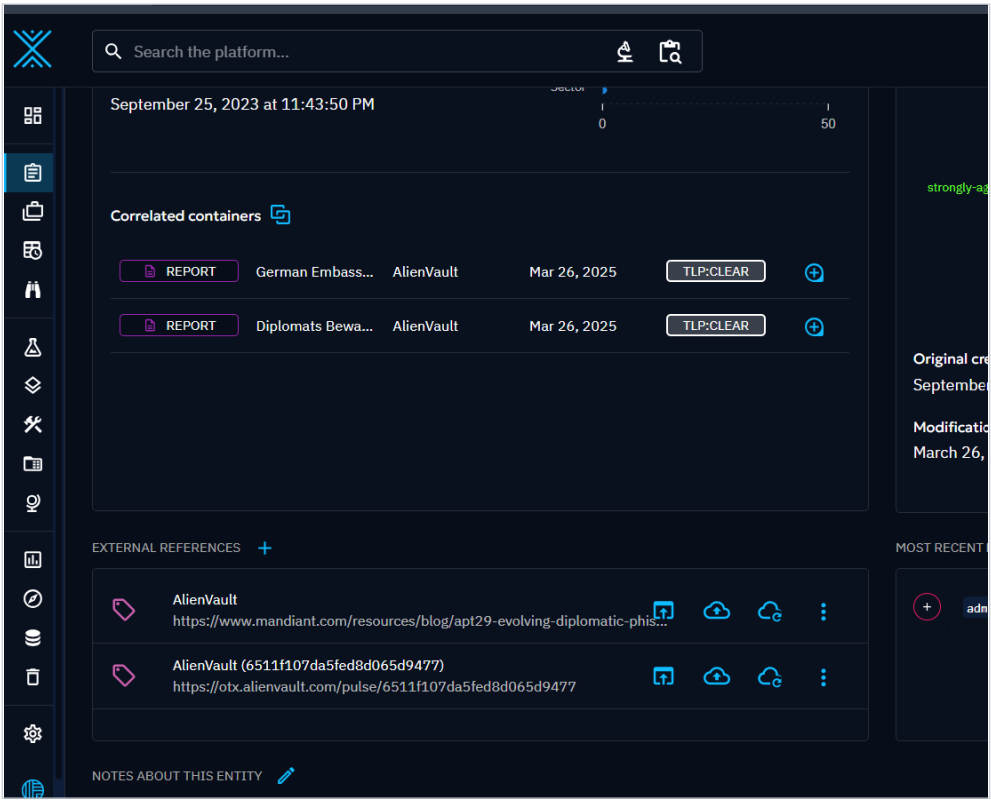


Figure 11. Overview of the Backchannel Diplomacy report: correlated containers and external references to the source analysis.

The section titled **April 2023: Old Wine in a New Bottle** shows APT29 modifying its standard delivery chain. It re-used a diplomatic event lure that spoofed the Czechia Embassy and invited targets to a wine tasting on April 13, 2023. The document contained a link to the phishing site **https://sylvio[.]com[.]br/form.php**, which delivered either an ISO or a ZIP archive. Victims who passed server-side filtering received the archive straight from the compromised web server, without ROOTSAW. Dropping the HTML smuggling stage most likely reduced the forensic artifacts left on the host.

April 2023: Old Wine in a New Bottle

In April 2023, APT29 continued to modify its standard malware delivery chain, introducing a new technique for malware delivery. In this operation, APT29 re-used one its frequent diplomatic event-themed lure documents spoofing the Czechia Embassy (more commonly known as the Czech Republic) that invited targets to a wine tasting event on April 13, 2023. The document contained a link to the phishing website “https://sylvio[.]com[.]br/form.php”, which delivered either an ISO or a ZIP archive to the victim.

- Rather than using ROOTSAW, victims were delivered a malicious ISO or ZIP file directly from the compromised web server if they successfully passed the server-side filtering checks.
- The decision to remove the HTML smuggling stage of the infection chain was likely intended to further reduce the number of forensic artifacts left on the host that are prone to detection or later analysis.

Figure 12. Source analysis of the April 2023 operation: the Czechia Embassy lure linking to the phishing site that delivered an ISO or ZIP.

Phase 7 - March 2023: Earthquake-Themed Türkiye Campaign

The same report covers a March 2023 campaign against Türkiye. The phishing waves impersonated the Turkish Deputy Minister of Foreign Affairs and used content about the February 2023 earthquake. In the first wave, a link generated with a URL shortening service (**tinyurl[.]com/mrxcjsbs**) redirected victims to a ROOTSAW dropper on an actor-controlled compromised website, hosted on the hostname **www.willyminiatures[.]com** (path /e-yazi.htm/?v=bc78a8d162c6). This was the first time Mandiant saw APT29 add a URL shortener as an extra layer of obfuscation.

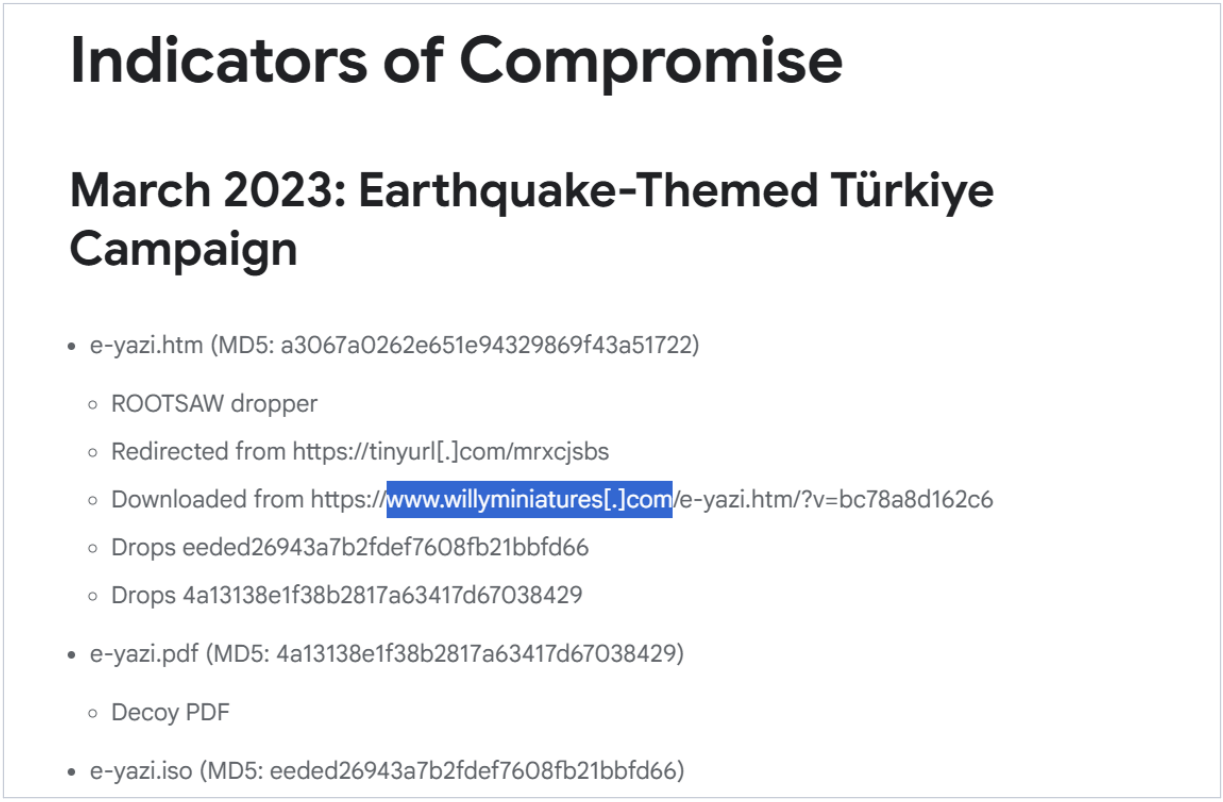


Figure 13. March 2023 Türkiye campaign indicators: the ROOTSAW dropper e-yazi.htm downloaded from the compromised host (highlighted).

The dropper **e-yazi.htm** then dropped further files, including the malicious ISO **e-yazi.iso** and a decoy PDF named **e-yazi.pdf**. The newer ROOTSAW variant included user-agent anti-analysis guardrails: it delivers the ISO only when the user-agent contains "Windows NT" and does not contain ".NET", and otherwise serves the decoy PDF. This filters out automated downloaders and non-Windows systems, reducing the chance of exposing the malware to researchers.

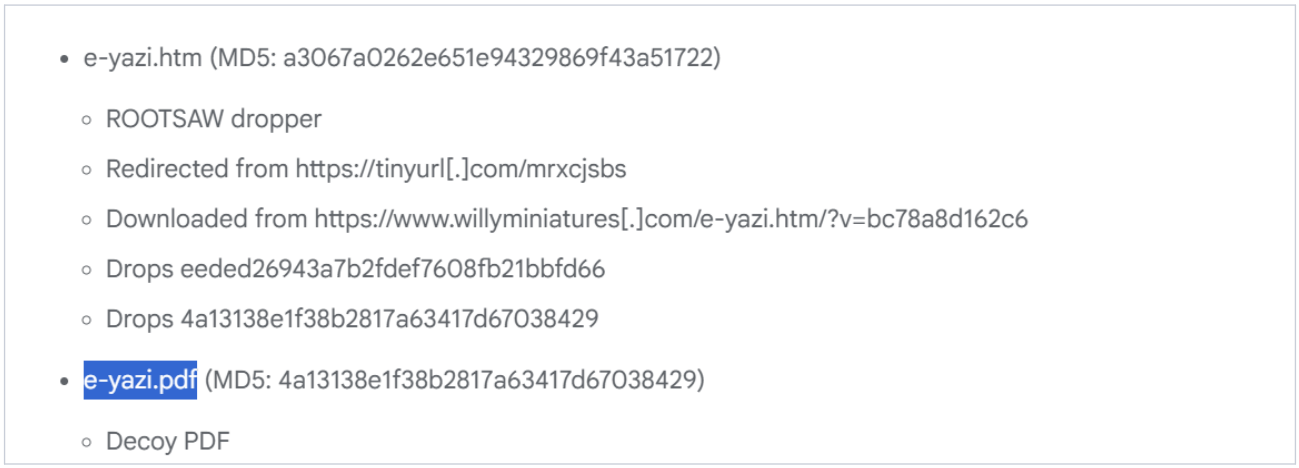


Figure 14. The decoy file e-yazi.pdf listed with its MD5 beside the e-yazi.htm dropper record.

Phase 8 - June 2023: Split ROOTSAW Campaign

In late June 2023, Mandiant identified another campaign with a new ROOTSAW variant aimed at a European government. The emails came from a compromised North American government address and were crafted as an invitation to a public holiday celebration from Norwegian embassy personnel. Two delivery mechanisms were used: a PDF (MD5 b4141aa8d234137f0b9549a448158a95) linking to an actor-hosted ROOTSAW variant, and emails with an attached SVG file instead of the usual HTML payload.

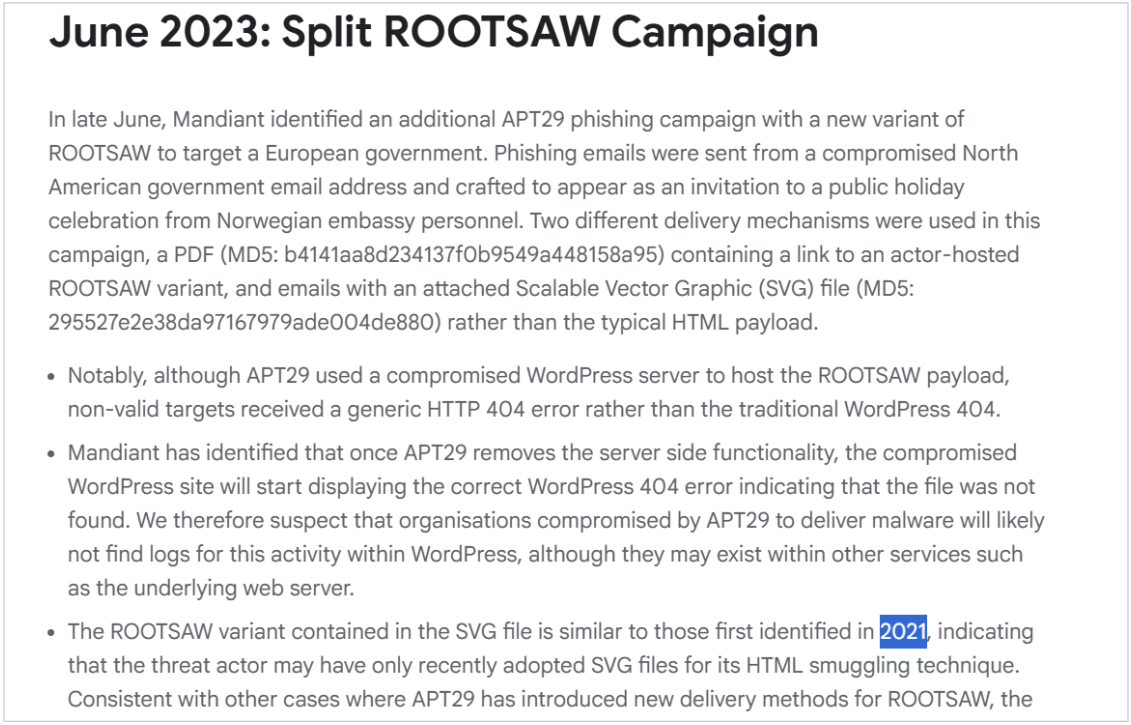


Figure 15. June 2023 Split ROOTSAW campaign: the SVG-based variant resembles ones first identified in 2021.

The SVG-based ROOTSAW dropper carries the MD5 **295527e2e38da97167979ade004de880**. Because the variant is similar to those first seen in 2021, APT29 appears to have only recently adopted SVG files for HTML smuggling, and it reverted to a primitive ROOTSAW payload without anti-analysis hardening, as it has done with other new delivery methods. Two defensive details matter here: the compromised WordPress server returned a generic HTTP 404 to non-valid targets, and once the actor removes the server-side functionality the site shows the normal WordPress 404, so victims may find little in WordPress logs and should check the underlying web server instead.

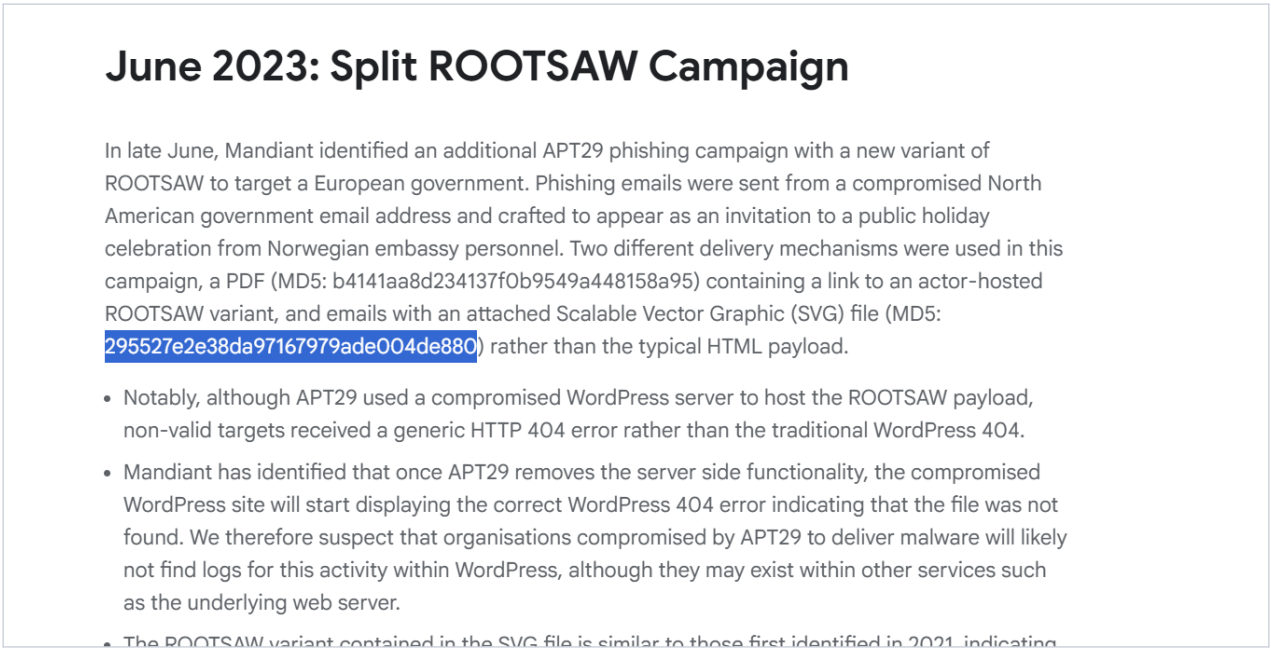


Figure 16. MD5 of the SVG-based ROOTSAW dropper highlighted in the campaign description.

Phase 9 - 2023 EU Governments Campaign: Weaponized Document Infrastructure

The last campaign I examined targeted EU governments assisting Ukraine. In Analyses > Reports, searching for APT29 returned six reports. I selected **NOBELIUM Uses Poland's Ambassador's Visit to the U.S. to Target EU Governments Assisting Ukraine**, dated March 18, 2023, authored by AlienVault and labeled phishing, apt29 and nobelium. NOBELIUM is another name for APT29, used in particular by Microsoft.

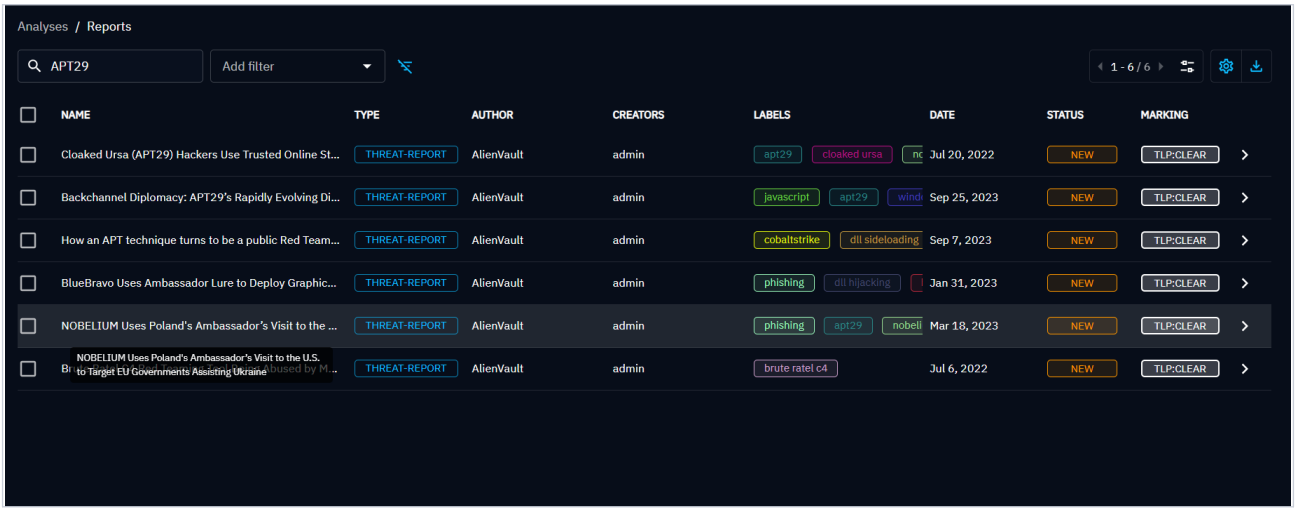


Figure 17. OpenCTI Reports list filtered for APT29 (six reports), including the NOBELIUM report on Poland's Ambassador's visit.

In the report's Observables tab, ten observables are listed, a mix of file hashes and URLs, all labeled apt29 and bugsplatrc64. The type filter on the right-hand panel isolates the URL observables. Two remain: **https://literaturaelsalvador[.]com/Schedule.html** and **https://literaturaelsalvador[.]com/Instructions.html**, both hosted on a compromised website impersonating an El Salvador-based library and used with a weaponized document.

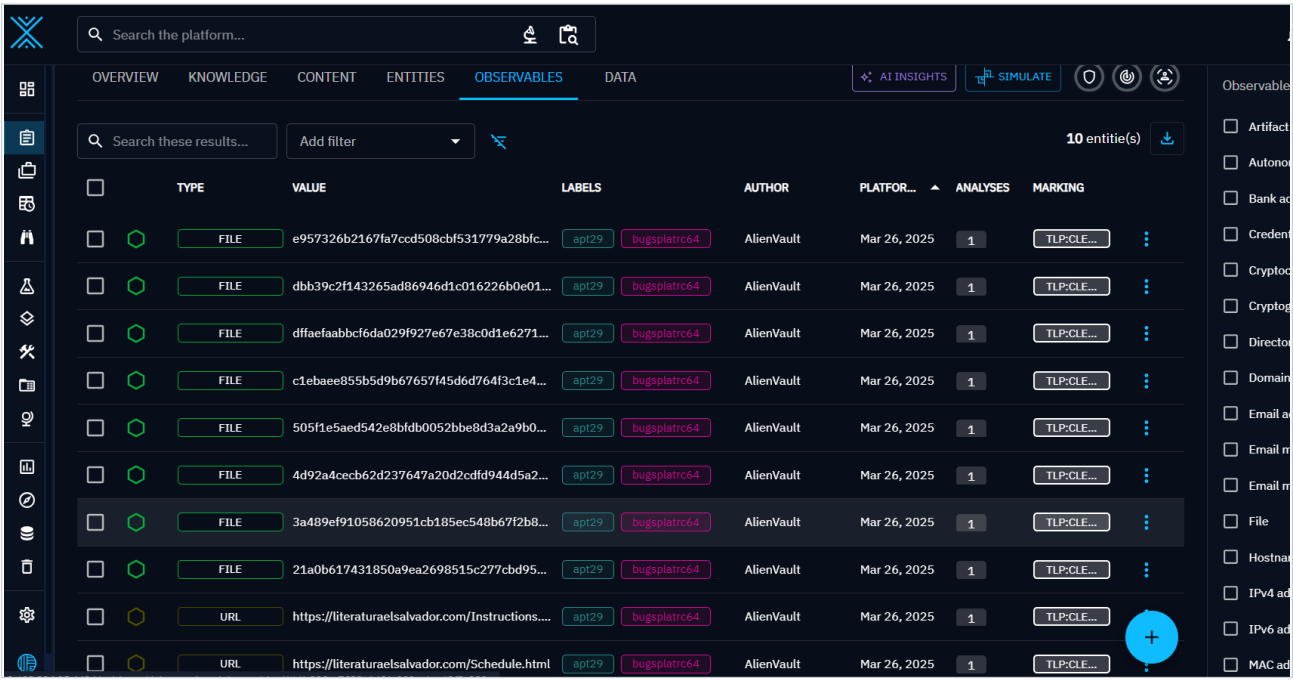


Figure 18. Observables of the NOBELIUM report: ten observables labeled apt29 and bugsplatrc64, including the two literaturaelsalvador.com URLs.

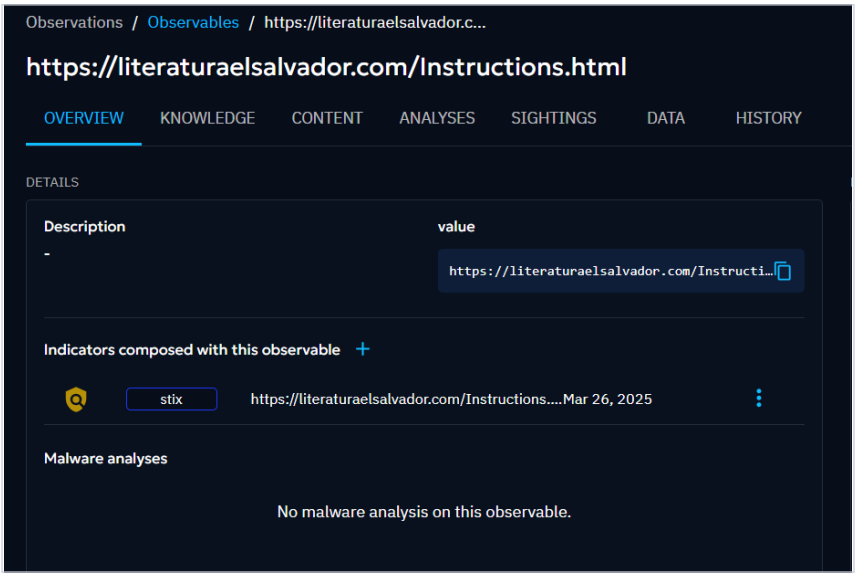


Figure 19. Observable record for literaturaelsalvador.com/Instructions.html, with its linked STIX indicator.

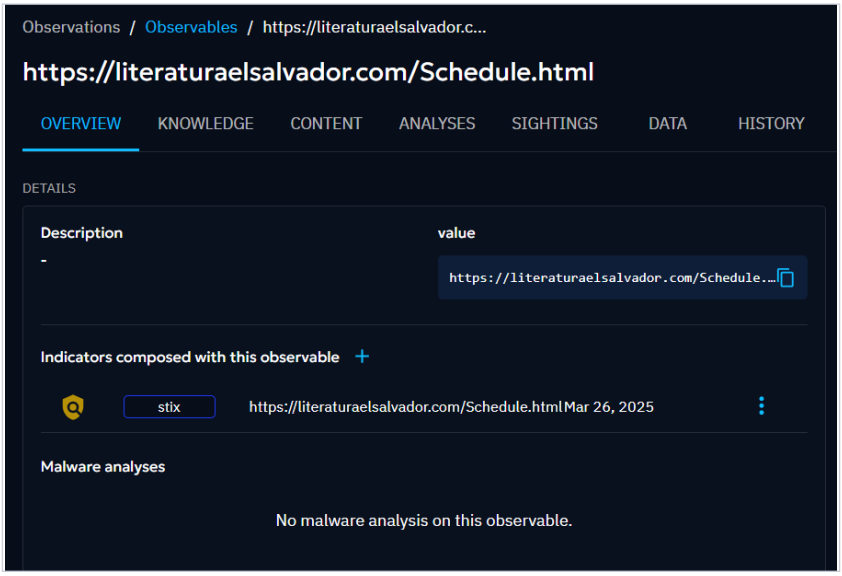


Figure 20. Observable record for literaturaelsalvador.com/Schedule.html, with its linked STIX indicator.

Phase 10 - Payload Execution Chain: Malicious Shortcut

Both URLs delivered ISO files containing a shortcut (.lnk) and a DLL with matching hashes. To understand execution, I returned to the report's External References, which include an AlienVault OTX pulse. The pulse lists 23 indicators of compromise (URLs, MD5, SHA1 and SHA256 hashes, a YARA rule and an IPv4 address) and is tagged APT29, Nobelium, BugSplatRc64, trojan and phishing.

From the MD5 entries I opened **38b05aa4b5ba651ba95f7173c5145270**, the shortcut file inside the ISO. The analysis shows a file score of 10, marked malicious, with file type "LNK - MS Windows shortcut". The shortcut metadata shows the target path `C:\Windows\system32\rundll32.exe` and the command line arguments `BugSplatRc64.dll,InitiateDs`. Combined, the shortcut executes:

```
C:\Windows\system32\rundll32.exe BugSplatRc64.dll,InitiateDs
```

This abuses rundll32.exe, a legitimate Windows utility for running DLLs, to load the malicious BugSplatRc64.dll and call its InitiateDs export, so the payload runs through a trusted system binary.

5. Campaign Timeline

Date	Event
Jul 20, 2022	Report published on APT29 abusing trusted online storage services (crossfity[.]com, techspaceinfo[.]com)
Early Mar 2023	Earthquake-themed Türkiye campaign, first wave: tinyurl link redirecting to ROOTSAW dropper e-yazi.htm
Mar 18, 2023	Report published on the Poland Ambassador's visit lure campaign (literaturaelsalvador[.]com URLs)
Apr 13, 2023	Date of the wine tasting event used in the Czechia Embassy lure (April 2023 operation)
Late Jun 2023	Split ROOTSAW campaign: PDF and SVG delivery, Norwegian embassy holiday lure
Sep 25, 2023	Backchannel Diplomacy report published, consolidating the 2023 operations

Report dates are publication dates in the intelligence records, not necessarily the dates of the activity.

6. MITRE ATT&CK Mapping

Technique	ID	Observed activity
Phishing: Spearphishing Link	T1566.002	Embassy-themed lures linking to ROOTSAW and ISO/ZIP hosting sites
Phishing: Spearphishing Attachment	T1566.001	SVG file attached to the June 2023 emails
Obfuscated Files or Information: HTML Smuggling	T1027.006	ROOTSAW HTML and SVG droppers delivering ISO and ZIP archives
Compromise Infrastructure	T1584	Compromised WordPress server and compromised websites hosting payloads
User Execution: Malicious File	T1204.002	ISO containing a shortcut and DLL opened by the victim
System Binary Proxy Execution: Rundll32	T1218.011	Shortcut runs rundll32.exe BugSplatRc64.dll,InitiateDs
Proxy: Domain Fronting	T1090.004	meek plugin tunnels Tor traffic through HTTPS connections
Data Transfer Size Limits	T1030	Most recently observed exfiltration pattern in the actor profile
Exfiltration Over Alternative Protocol	T1048	Most recently observed exfiltration pattern in the actor profile

7. Indicators of Compromise

Type	Value	Notes
Domain	`crossfity[.]com`	Linked to Cobalt Strike, EnvyScout and APT29
Domain	`techspaceinfo[.]com`	Documented in the same campaign report
URL	`https://sylvio[.]com[.]br/form.php`	Phishing site delivering ISO or ZIP (April 2023)
URL	`https://tinyurl[.]com/mrxcjsbs`	URL shortener redirecting to ROOTSAW (March 2023)
URL	`https://www.willyminiatures[.]com/e-yazi.htm/?v=bc78a8d162c6`	Compromised site hosting the ROOTSAW dropper
Hostname	`www.willyminiatures[.]com`	Hostname used in the Türkiye campaign
URL	`https://literaturaelsalvador[.]com/Schedule.html`	Weaponized document infrastructure
URL	`https://literaturaelsalvador[.]com/Instructions.html`	Weaponized document infrastructure
File / MD5	`e-yazi.htm - a3067a0262e651e94329869f43a51722`	ROOTSAW dropper
File / MD5	`e-yazi.iso - eeded26943a7b2fdef7608fb21bbfd66`	Malicious ISO dropped by e-yazi.htm
File / MD5	`e-yazi.pdf - 4a13138e1f38b2817a63417d67038429`	Decoy PDF
File / MD5	`b4141aa8d234137f0b9549a448158a95`	PDF linking to ROOTSAW (June 2023)
File / MD5	`295527e2e38da97167979ade004de880`	SVG-based ROOTSAW dropper (June 2023)
File / MD5	`38b05aa4b5ba651ba95f7173c5145270`	Malicious LNK file inside the ISO
File name	`BugSplatRc64.dll`	DLL loaded by the shortcut (export InitiateDs)
Command line	`C:\Windows\system32\rundll32.exe BugSplatRc64.dll,InitiateDs`	Shortcut execution command

8. Impact Assessment

The intelligence describes an actor that blends espionage objectives with constantly changing delivery methods: a URL shortener layer, user-agent filtering, SVG-based smuggling, convincing diplomatic lures and compromised legitimate sites that return normal-looking errors to unintended visitors. These choices lower the number of artifacts left on disk and in logs, so detection that depends on a single signature will miss them. If any of our users received lures matching these themes, or any of the indicators listed above appear in our telemetry, the affected hosts should be treated as potentially compromised and investigated for follow-on tooling such as Cobalt Strike or Mimikatz.

9. Recommendations

- Search mail, proxy, DNS and EDR telemetry retroactively for every domain, URL, file name and hash listed in the indicators section.
- Block the listed domains and URLs, and monitor for new infrastructure through the APT29 intrusion set in OpenCTI.
- Alert on rundll32.exe launched from a shortcut with a DLL argument, especially from a mounted ISO, and on LNK, DLL and ISO files delivered together.
- Restrict or inspect SVG attachments and downloads of ISO or ZIP files from unfamiliar sites, and review the web server logs (not only WordPress logs) of any site that may have served ROOTSAW.
- Add detections for Tor and domain-fronted HTTPS traffic (meek) and for data leaving the network in small chunks or over non-standard protocols (T1030 and T1048).
- Keep consuming the actor's STIX indicators from OpenCTI into the SIEM and EDR so new indicators reach detection quickly.

10. Conclusion

Using OpenCTI, I built a complete picture of APT29: two major campaigns, a 15-tool arsenal including meek, 160 ATT&CK attack patterns with recent exfiltration techniques, and a chain of 2023 phishing operations that ended in a malicious shortcut calling rundll32 to load BugSplatRc64.dll. The extracted indicators and the detection ideas above give the SOC concrete next steps for hunting, blocking and hardening against this actor.